

AAVA Agents Service - Data Flow diagram

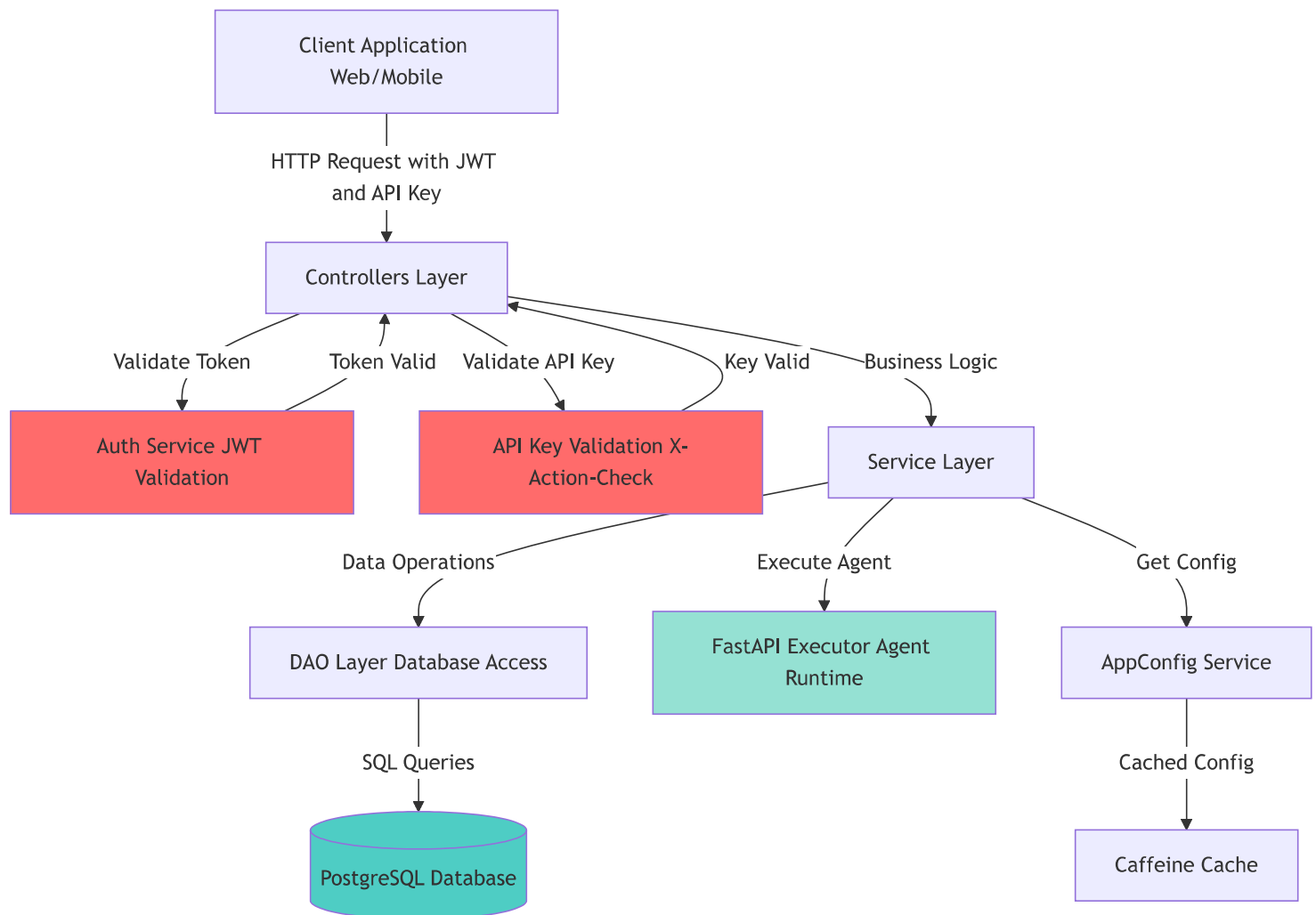
Last updated by | Saravanan Ramalingam | Oct 30, 2025 at 4:28 PM GMT+5:30

AAVA Agents Service - Security Dataflow Diagrams

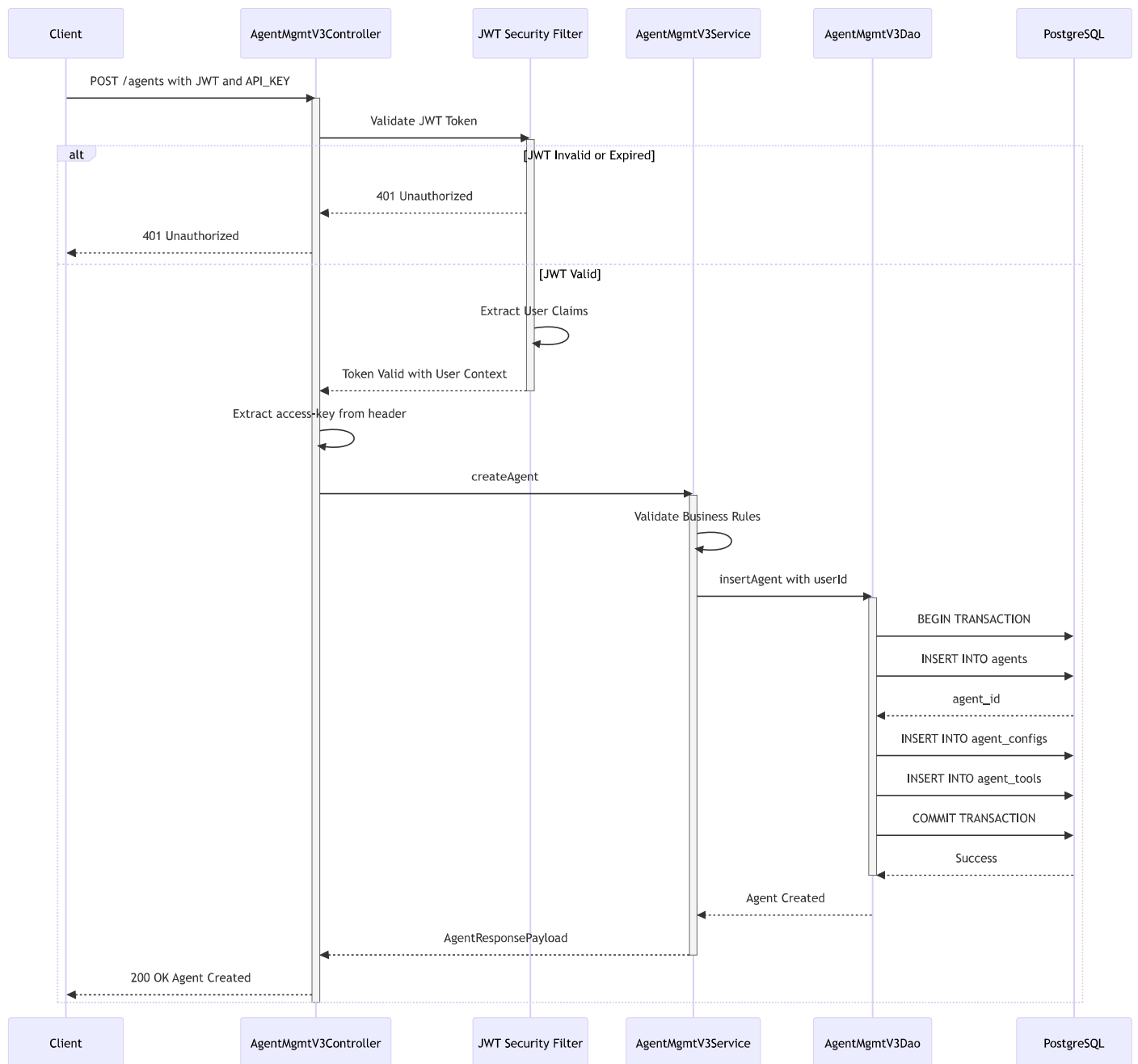
Document Information

- **Service:** Agents
- **Date:** October 30, 2025

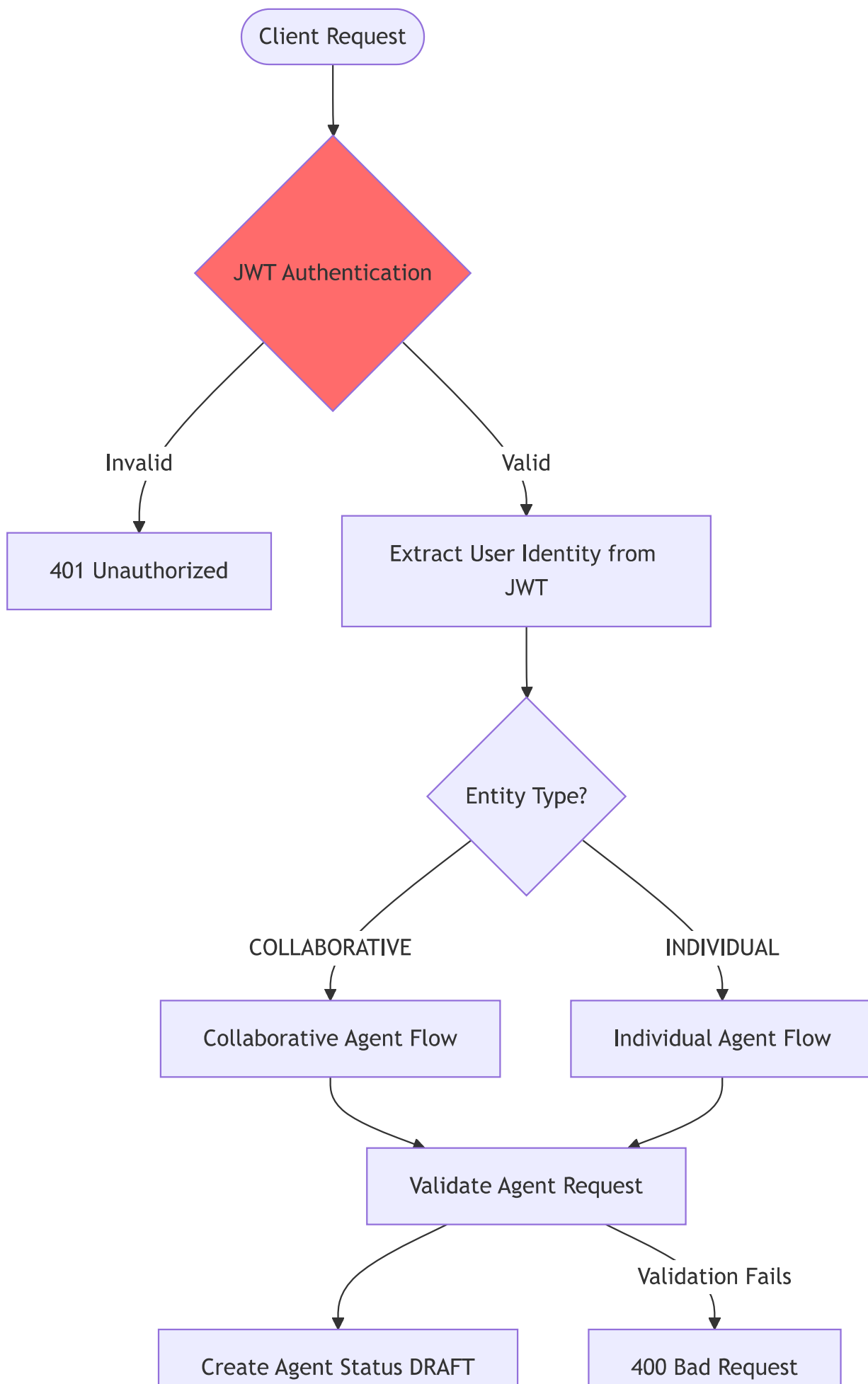
1. High-Level System Architecture



2. Authentication & Authorization Flow



3. Agent Creation and Management Dataflow

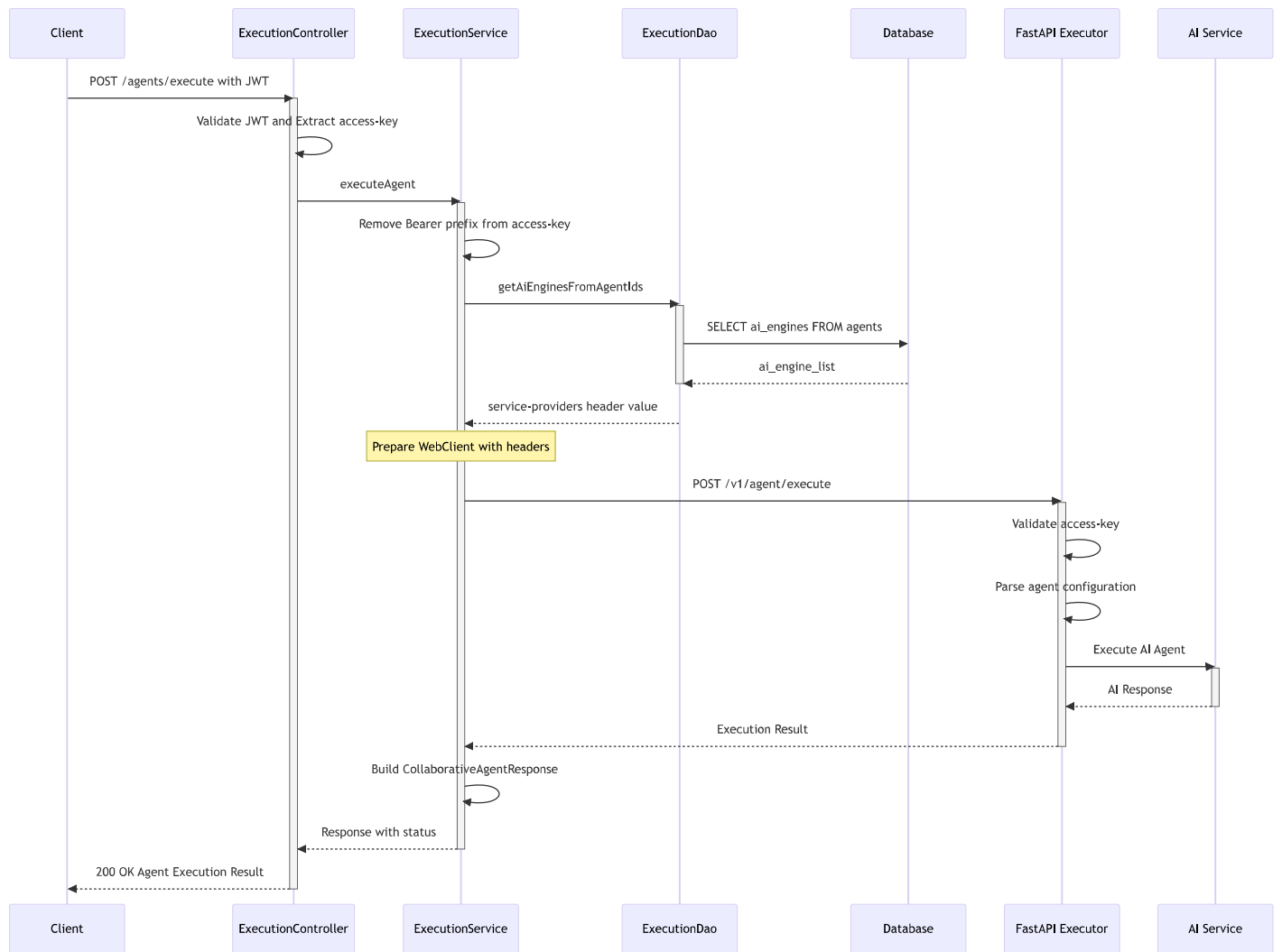


```

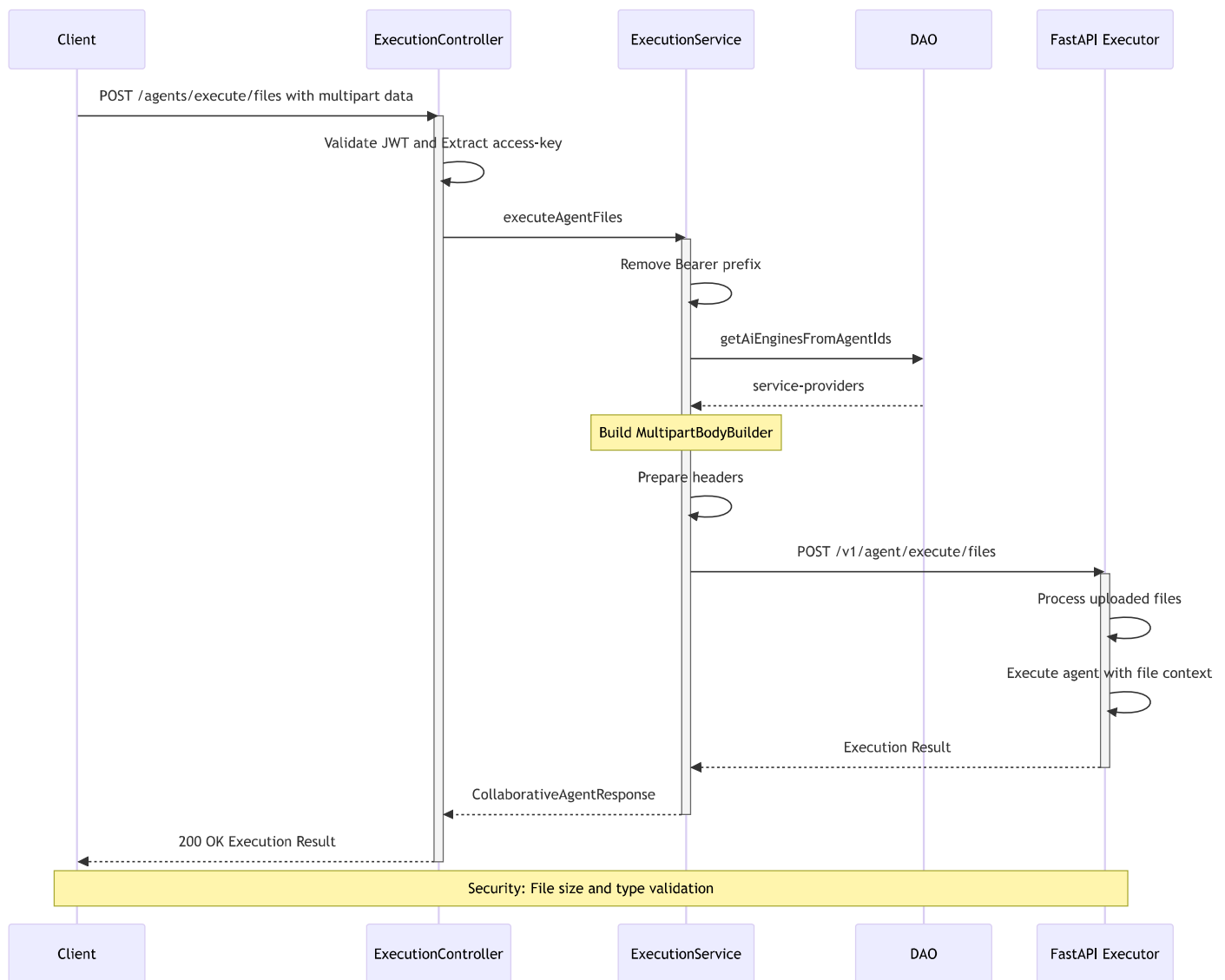
graph TD
    Start(( )) --> DB_BEGIN[Database Transaction BEGIN]
    DB_BEGIN -- "Agent Created By User" --> DRAFT[DRAFT]
    DRAFT -- "DB Error" --> ROLLBACK[ROLLBACK]
    ROLLBACK --> IN_REVIEW[IN_REVIEW]
    IN_REVIEW -- "Approve Request" --> APPROVED[APPROVED]
    APPROVED -- "Archive Agent" --> ARCHIVED[ARCHIVED]
    IN_REVIEW -- "Reject Request" --> REJECTED[REJECTED]
    REJECTED -- "Agent Rejected" --> End(( ))
    IN_REVIEW -- "Agent Active" --> End
    DRAFT -- "Return to Draft" --> DB_BEGIN
    DRAFT -- "Submit for Review" --> IN_REVIEW
    IN_REVIEW -- "Delete Request" --> ARCHIVED
    IN_REVIEW -- "Delete Agent" --> ARCHIVED
    
```

The flowchart illustrates the lifecycle of an agent, starting with a 'Database Transaction BEGIN' and ending with a final state. The process involves several states and transitions, including 'DRAFT', 'ROLLBACK', 'IN_REVIEW', 'APPROVED', 'REJECTED', and 'ARCHIVED'. Key components include 'Agents table', 'agent_configs' (with Security: RBAC, Reviewer or Admin privileges, Audit trail logging), 'agent_tools', 'SERT Knowledgebases', and '500 Internal Error'.

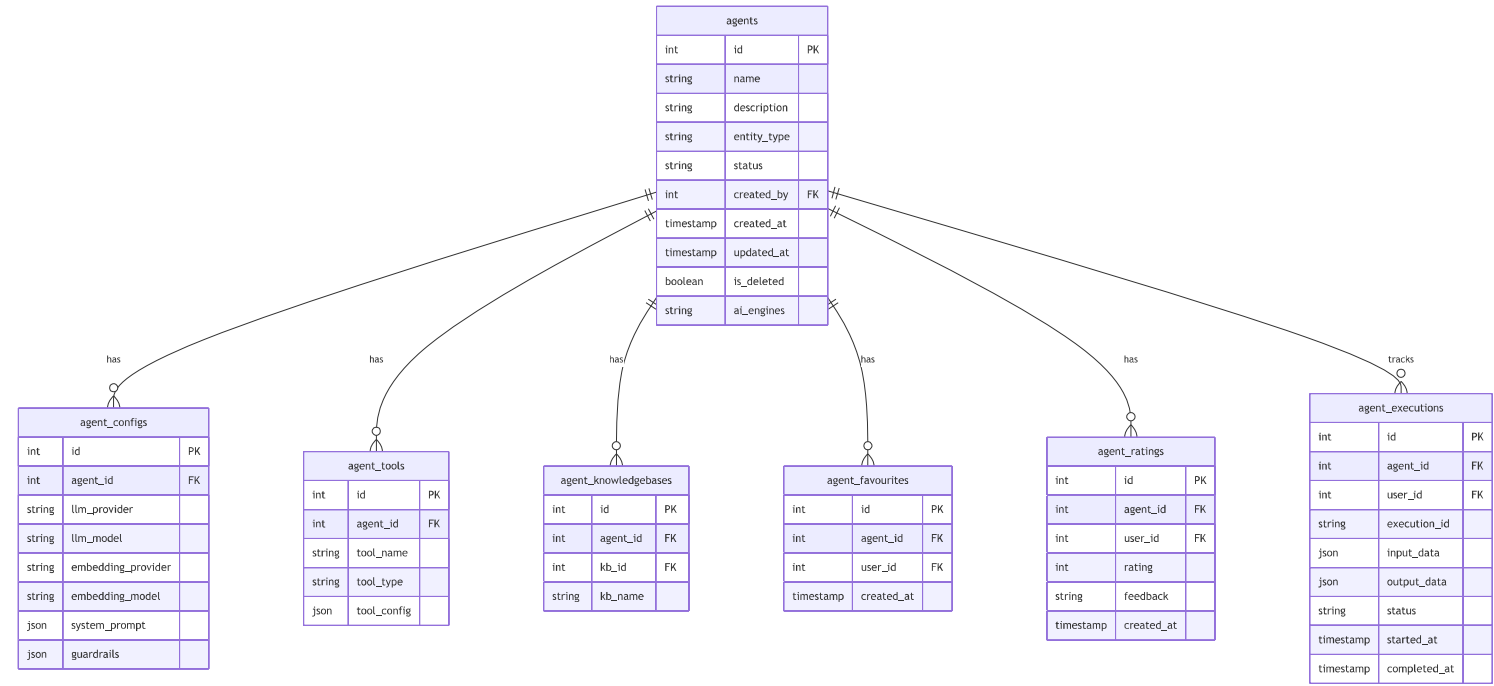
```
graph TD; A[COMMIT Transaction] --> B[Return Agent ID]; B --> C([200 OK Response]);
```



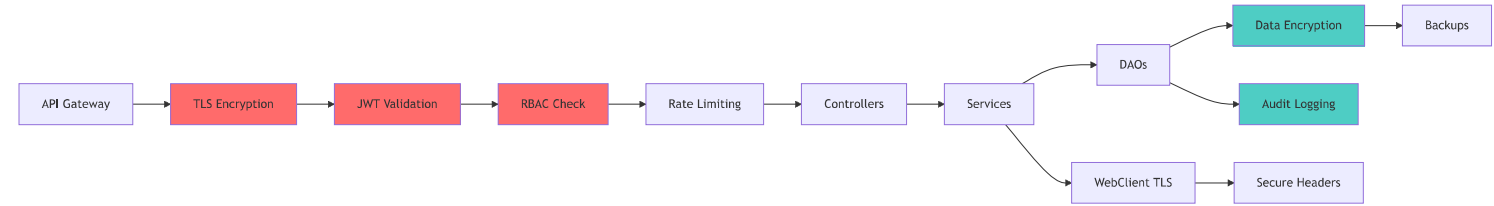
6. Agent Execution with File Upload



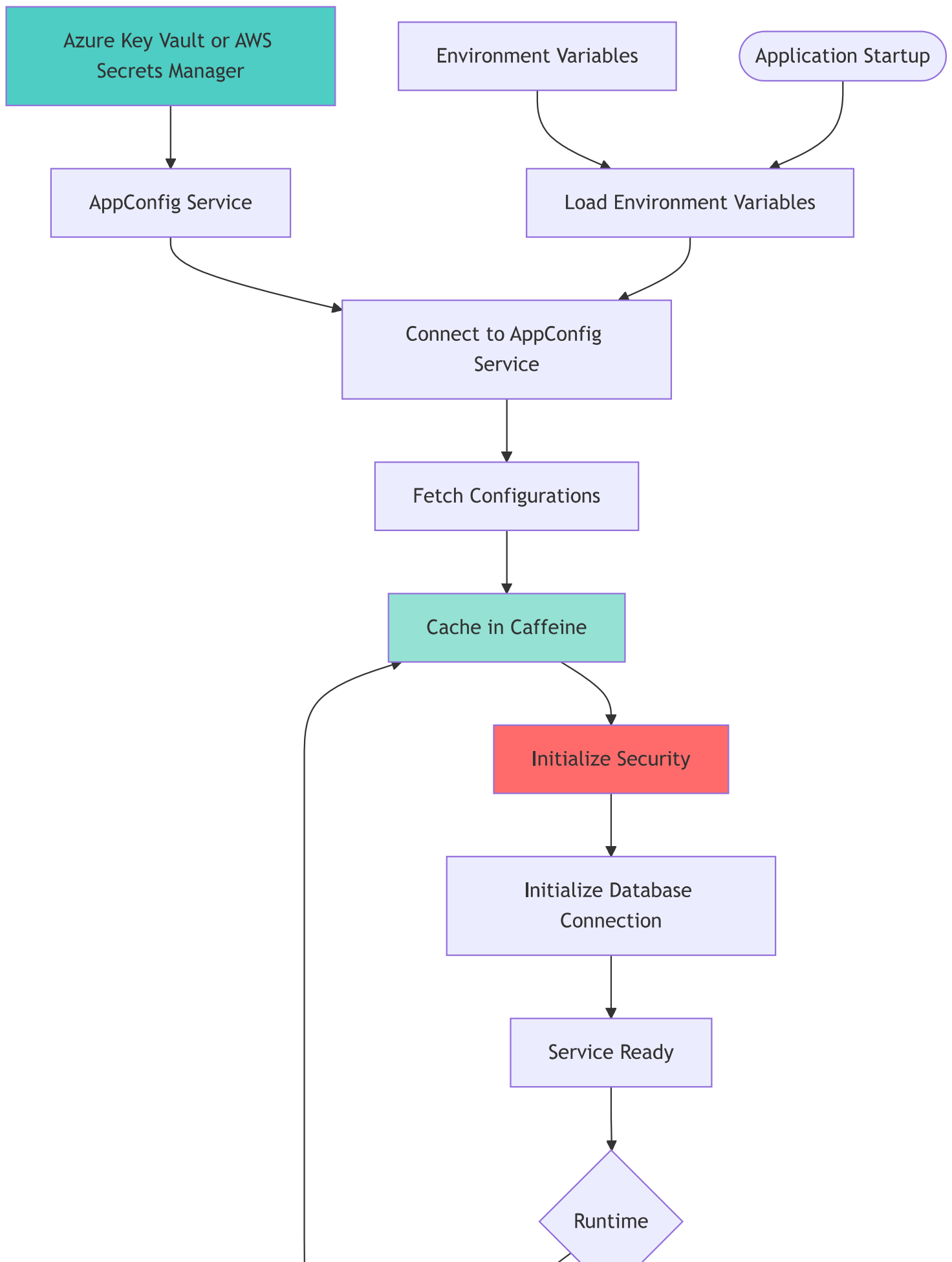
7. Database Schema and Data Relationships



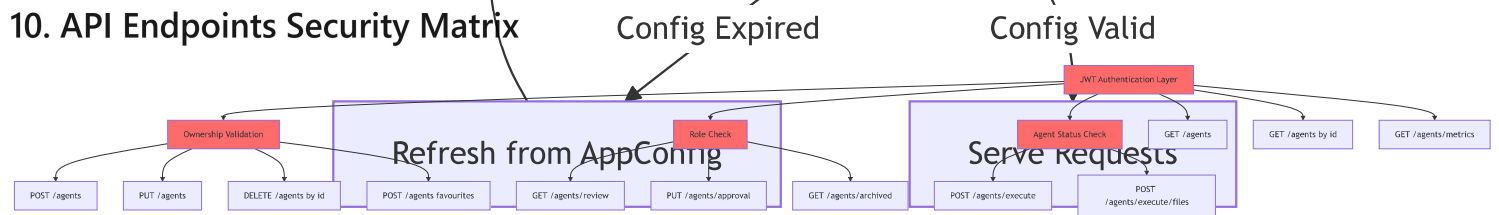
8. Security Controls and Data Flow



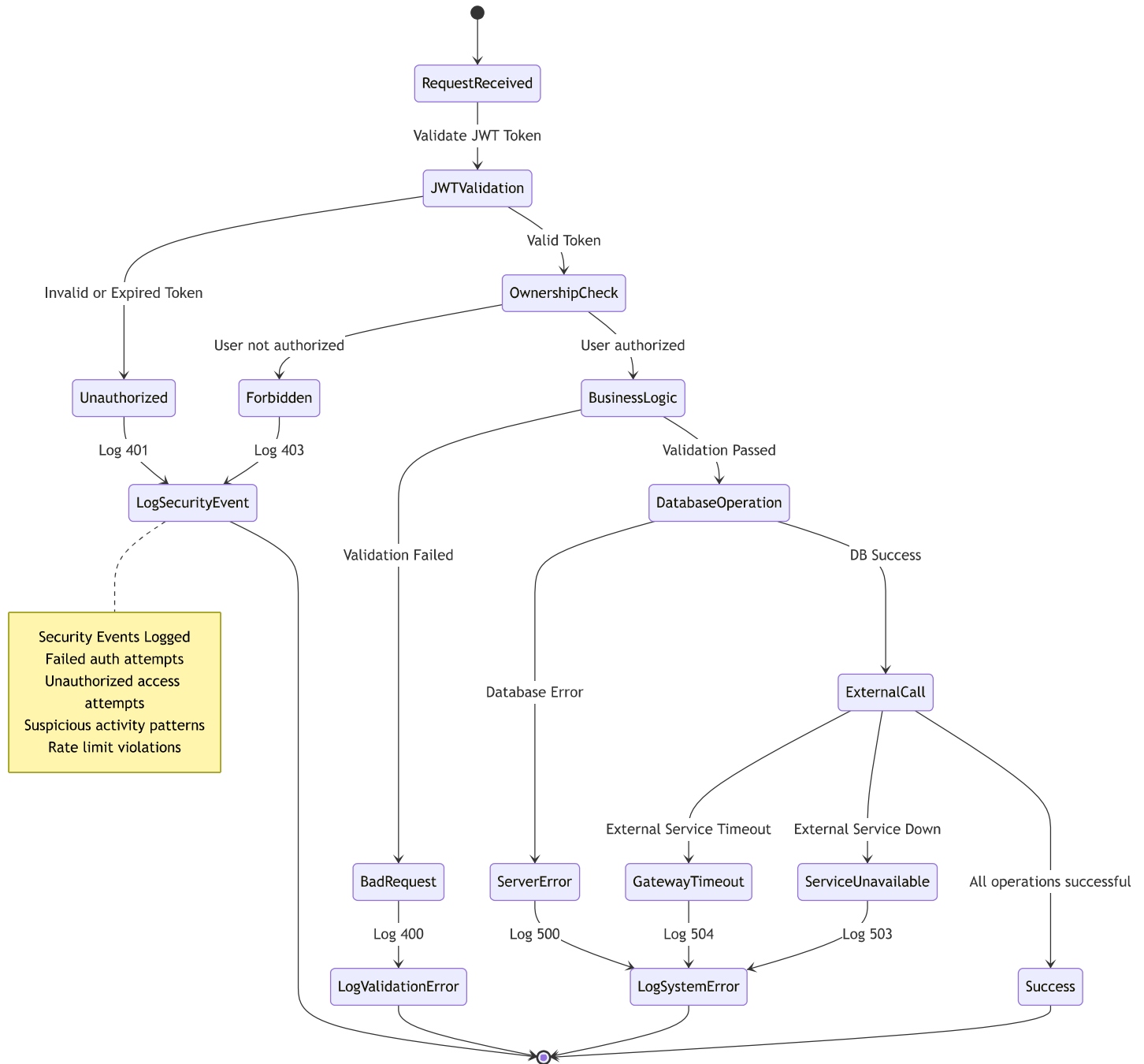
9. Configuration and Secrets Management



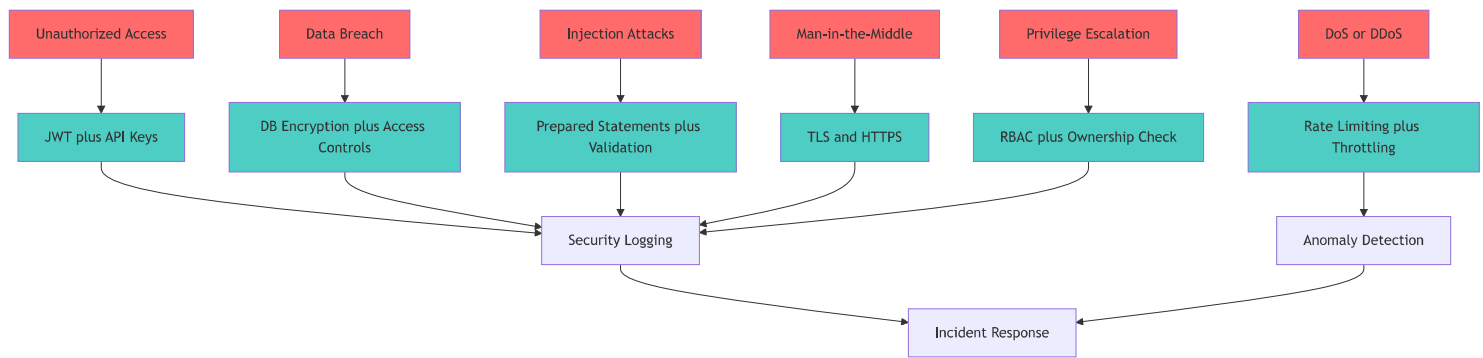
10. API Endpoints Security Matrix



11. Error Handling and Security Events



12. Threat Model and Mitigation



Summary of Security Controls

Authentication

- JWT Bearer Token validation
- API Key authentication via X-Action-Check header
- Token expiration and refresh mechanisms
- User identity extraction from JWT claims

Authorization

- Role-Based Access Control (RBAC)
- Ownership validation for CRUD operations
- Agent status-based execution control
- Admin-only review and approval operations

Data Protection

- Database encryption at rest
- TLS/HTTPS for data in transit
- Secure configuration management via AppConfig Service
- Secrets stored in environment variables and key vaults

Input Validation

- Request payload validation
- SQL injection prevention using Prepared Statements
- File upload validation and size limits
- Business logic validation

Audit and Monitoring

- Security event logging
- Audit trails for agent operations
- User activity tracking
- Exception and error logging

External Communication

- Secure WebClient configuration
 - Header forwarding controls
 - Timeout and retry mechanisms
 - Service-to-service authentication
-

Recommendations for Security Team

1. **Review JWT Token Policies** - Ensure token expiration times are appropriate
2. **Implement Rate Limiting** - Add API gateway rate limiting per user or IP
3. **Enable API Monitoring** - Set up alerts for suspicious patterns
4. **Regular Security Audits** - Schedule periodic code and configuration reviews
5. **Penetration Testing** - Conduct regular penetration tests on agent execution flows
6. **Data Classification** - Ensure sensitive agent data is properly classified
7. **Incident Response Plan** - Document incident response procedures for security events